CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat 10:15. PaketPro'nun servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; ışık perdesi parametreleri henüz doğrulanmadı. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey zaman ve kanıttır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

   Önce emniyet sorumlusunu ve üretim müdürünü, ardından BT/OT güvenlik sorumlusunu ve gerekirse üretici servisini ararım. Eylemler: (1) makineyi normal stopla durdurup operatörü çene/bıçak bölgesinden uzaklaştırmak, (2) uzak bakım erişimini ve servis hesabını kapatmak, (3) kanıtı korumak (log, ekran görüntüsü, PLC'nin mevcut hâli, saat notları). Resetlemem, gücü kesmem.

2. İlk 2 saat: Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Işık perdesi (test çubuğuyla kesince STO), kapak kilidi ve durma süresi testi yapılır; Safety PLC programı ve parametreleri yedekle/checksum ile karşılaştırılır. Korunan kanıt: uzak bakım ve firewall logları, 03:00 oturum kayıtları, PLC/HMI konfigürasyon kopyası, USB ve Wi-Fi kayıtları. Kapatılan hesap: admin/admin servis hesabı (parolası değiştirilir, uzak erişim kapalı kalır).

3. 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

   Ne oldu (varsayılan hesapla yetkisiz erişim şüphesi), ne zaman fark edildi (10:15), hangi ürün ve sürüm etkilendi, emniyet fonksiyonları doğrulandı mı, alınan ilk önlemler ve irtibat kişisi. Net olmayan kısımlar araştırılıyor diye belirtilir.

4. 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (zayıf kimlik doğrulama + internete açık erişim) ve etki analizini OT güvenlik ekibi yapar; hangi parametrenin değiştiğini ve emniyet doğrulama sonucunu emniyet mühendisi yazar; kalıcı önlemi (VPN, MFA, jump server) BT/OT sorumlusu planlar; bildirimi yönetim ve uyum sorumlusu onaylayıp gönderir.

5. 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

   Uzak bakım, VPN ve firewall logları; servis hesabı kimlik doğrulama kayıtları; PLC ve Safety PLC program sürümleri ile değişiklik kayıtları; HMI logları; yedekler; emniyet fonksiyon test tutanakları; olay zaman çizelgesi ve alınan kararlar.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.